

Who Can Call This MCP Tool?

OAuth, Resource Binding,
and Runtime Policy

Brian Benz

Principal AI Advocate, Microsoft

MCP Dev Summit Toronto | October 6, 2026

**SYNTHETIC
REFUND**

User
+ client
+ order

Three different questions

Authentication

Who is calling?
Trusted identity

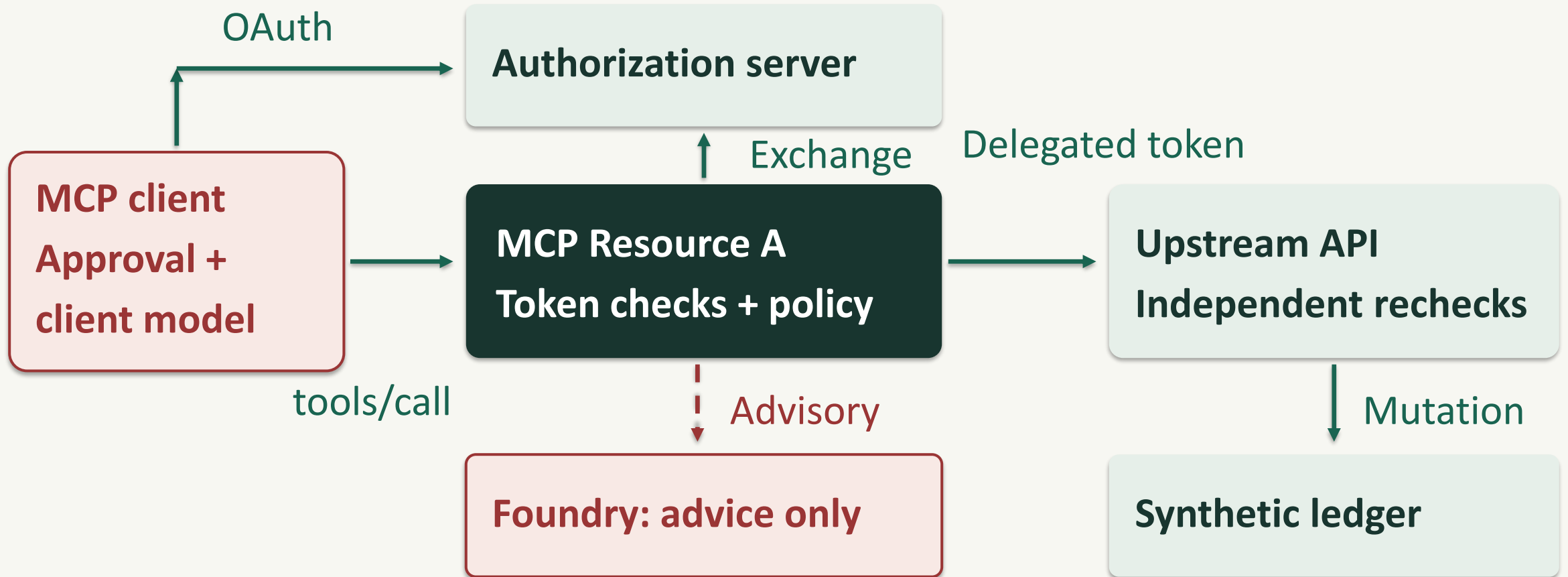
Approval

Did the human
intend it?
Client-owned choice

Authorization

May this principal
act on this object
right now?

Follow the trust boundary



RED, LABELED: UNTRUSTED CLIENT / MODEL INPUT

Who enforces what?

Client	Human approval	Not server permission
Authorization server	Identity + audience	Not object policy
MCP server	Tool + object policy	Must decide at call time
Upstream API	Mutation checks	No token passthrough
Model	Advice only	Never grants authority

Platform filtering is separate from authorization.

Three rules to take home

1

Bind tokens to resources.

Check the audience at each service.

2

Scopes are verbs, not objects.

Check ownership and business state.

3

Assume Approve was clicked.

Decide on the server anyway.

Control map, resources, Q&A

Client	Human approval
Authorization server	Identity + audience
MCP server	Tool + object policy
Upstream API	Mutation checks
Model	Advice only

github.com/bbenz/mcp-tool-calling

QUESTIONS 23:00-25:00 | HARD STOP 25:00



**Code +
control map**

The authorization trace

- | | | |
|----------|--------------------------------|--|
| 1 | No token -> HTTP 401 | WWW-Authenticate points to resource metadata |
| 2 | Discover the endpoints | Protected Resource Metadata -> AS metadata |
| 3 | Bind the authorization | PKCE S256 + resource in both requests |
| 4 | Validate, then call | Trusted keys, issuer, audience, lifetime, identity |

Policy at tools/call

Token validation precedes `policy.evaluate`.

Dana: missing Refunds.Write

R003 / POLICY_MISSING_SCOPE

Sam: ineligible ORD-1004

R200 / POLICY_ORDER_NOT_REFUNDABLE

Sam: above per-call ceiling

R203 / amount exceeds per-call limit

Unapproved client

R001 / POLICY_CLIENT_NOT_ALLOWED

One refund. One ledger change.

Sam | ORD-1001 | CAD 40.00 = 4000 minor units

Before

0 minor units

First call

4000

Replay: false

Same-key retry

4000

Replay: true

New downstream audience. Same human. No app-only fallback.

Hints and approval are not permission

Client-owned

Annotations guide a UI.

Cancel stops sending.

Approve permits sending.

Server-owned

Validate the token.

Evaluate object policy.

Deny even after approval.

Annotation tampering -> R003 / POLICY_MISSING_SCOPE

A genuine token can be wrong for you

Token intended for B

aud:

api://refund-mcp-b

Presented to Resource A

A rejects before dispatch

HTTP 401

AUTH_WRONG_AUDIENCE

Ledger unchanged

B-token acceptance: integration-test assertion, not rerun here.

Do not become the confused deputy

Sam asks

Has Refunds.Write.

Targets Riley's ORD-1003.

amount_minor=99000

Resource A decides

R006

POLICY_ORDER_NOT_ASSIGNED

Ledger unchanged

Ownership is checked BEFORE the amount ceiling.

Force the call. Keep the boundary.

- | | | |
|----------|-------------------------------|--|
| 1 | Untrusted input | ORD-1005: attacker-written notes |
| 2 | Advisory assessment | Model / filter / offline outcome is reported |
| 3 | Forced harness call | Sam -> ORD-1003, amount_minor=99000 |
| 4 | Deterministic boundary | R006 denies; ledger remains unchanged |

Three assessment outcomes. One policy.

Model answered

live: true

Advisory text only

Platform filtered

filtered: true

live: false

Not model refusal

Offline assessment

live: false

Explicit offline label

No generated advice

Audit is evidence, not enforcement

Allowed refund

identity_state: validated
policy_rule_id: R299
decision: allow
upstream_status: 201
ledger_changed: true

Rejected token

identity_state: untrusted
reason: wrong audience
decision: deny
No user attributed
ledger_changed: false

Request -> user -> client -> resource -> policy -> result

Run it four ways. Keep one policy.

1 Local scripts

PowerShell is the stage default.
Bash twins are available.

2 Scripts + browser UI

Run -> result -> ledger -> audit
Reporting, not authorization.

3 Docker Compose

Five local containers.
Recorded rehearsal, not rerun.

4 AKS

Recorded cloud rehearsal.
Not a production template.

The rest of the seven-rule checklist

- | | | |
|----------|--------------------------------------|---|
| 1 | Exchange downstream tokens | Preserve the human; fail closed. |
| 2 | Treat annotations as hints | Documentation does not grant permission. |
| 3 | Keep advice non-authoritative | Untrusted text cannot widen authorization. |
| 4 | Audit where you decide | Include denials; pseudonymize; deny by default. |

What was recorded. What remains open.

Recorded rehearsals

Local scripts + browser
Compose + AKS
Live Foundry advice
Platform filtering

Not established

Entra authentication
AKS workload identity
Separate Bicep deployment
Live client approval / KQL

No tamper-proof log, stolen-token replay defense, or production claim.

References for the next implementation

- | | | |
|----------|--------------------------------------|---|
| 1 | MCP authorization | Protected resources and security boundaries |
| 2 | Discovery + PKCE | RFC 9728 / RFC 8414 / RFC 7636 |
| 3 | Resource binding + delegation | RFC 8707 / RFC 7523 / Microsoft OBO |
| 4 | Implementation + control map | github.com/bbenz/mcp-tool-calling |